

SECURITY RESEARCH

Empirical Detection Posteriors

Closing the Loop from SIEM Firings to Breach Probability

AEGIS Labs Research
Version 1.1 | July 2026

7

Operationally distinct firing buckets

$\text{Beta}(\alpha, \beta)$

Per-technique detection posterior

0 Δ

Byte-identical fallback without
telemetry

Table of Contents

- 1 Executive Summary
- 2 The Illusory-Coverage Problem
- 3 The Firing Signal
- 4 Fitting the Posterior
 - 4.1 [From firings to evidence](#)
 - 4.2 [Cold start from the bucket](#)
- 5 Sampling Uncertainty into Breach Probability
- 6 The Regression Lock
- 7 Architecture Notes
- 8 Conclusion

1. Executive Summary

Breach-risk simulation usually models detection as an assumption. A technique is “covered” if a rule for it exists; the simulation discounts the attacker’s progress by that assumed coverage. But a deployed rule is not a firing rule. A rule can be installed and still never trigger, because its required log source is missing, it is disabled, or it has simply never matched anything. Treating deployed-but-silent coverage as real coverage produces a comfortable, and wrong, breach probability.

This paper describes how the Adversarix platform closes that loop by feeding *production telemetry*, meaning the actual firing behavior of deployed detection rules observed through the customer’s SIEM, back into the Monte Carlo breach simulation. The mechanism is a per-technique *empirical detection posterior*: a Beta distribution fit to real firing evidence that replaces a single global detection constant multiplied by a theoretical coverage score. Where a rule fires cleanly, detection rises and breach probability falls; where a rule is deployed but blind or disabled, detection falls *below* the assumed prior and breach probability rises, which is the honest correction of illusory coverage.

Two properties make the approach safe to ship into the heart of a risk score. Detection *uncertainty* propagates: a technique with three clean firings is less certain than one with three thousand, and the simulation samples that uncertainty rather than collapsing it to a point. And an organization with no SIEM telemetry falls back to exactly the prior behavior, byte-for-byte, so the feature is purely additive.

Key Finding

The failure mode this corrects is specific and common. A technique whose rule is deployed but whose required log source is missing cannot fire, yet it otherwise contributes the same detection confidence as a rule firing cleanly. The empirical posterior drives such a “deployed-blind” technique’s detection *below* the neutral prior, raising breach probability where coverage was an illusion. That is the loop reaching all the way into the risk math.

2. The Illusory-Coverage Problem

A breach simulation walks attack paths and, at each step, discounts the attacker’s progress by the probability that the step is detected and blocked. The quality of that discount depends entirely on the detection signal behind it. Three signals are commonly available, and they mean different things:

Signal	What it actually means
Theoretical coverage	The platform has a rule concept for this technique. Says nothing about deployment or firing.
Deployment status	A rule is installed in the customer’s detection stack. Says nothing about whether it fires.
Firing behavior	The deployed rule actually triggers, cleanly, in production. The only signal that reflects reality.

Most simulations run on the first or second signal. The gap is the third. A rule “deployed” but never firing scores identically to one firing cleanly, so the model credits coverage that does not exist. The correction is to route the firing signal into the detection term of the breach computation. But firing data is categorical, noisy, and uneven, so it cannot simply overwrite the assumption. It has to be modeled.

3. The Firing Signal

Detection connectors poll the customer's SIEM and reduce each deployed rule's behavior to a per-technique categorical bucket, plus richer per-rule firing counts and false-positive rates. Seven buckets capture the operationally distinct states:

Bucket	Meaning
detected	Deployed, enabled, log source healthy, fired, low false-positive rate.
deployed-noisy	Firing, but with a high false-positive rate. Untrustworthy coverage.
deployed-untested	Deployed with healthy logs, but has never fired.
deployed-blind	Deployed, but a required log source is missing or stale, so it <i>cannot</i> fire.
deployed-disabled	The rule exists but is turned off.
library-only	A rule template exists, but nothing is deployed to the SIEM.
gap	No rule and no template.

The bucket is the clean cold-start signal. The per-rule counts and false-positive rates are the richer evidence: clean firings accumulate as evidence *for* detection, false positives as evidence *against* its trustworthiness.

4. Fitting the Posterior

Each technique gets a detection-probability posterior modeled as a Beta distribution, starting from a symmetric, maximally uncertain prior, Beta(2, 2) with mean 0.5, and updated with firing evidence.

4.1 From firings to evidence

Joining deployed rules to their firing records yields, per technique, a count of clean firings and a count of false positives. These update the prior as pseudo-observations:

$$\alpha = \alpha_0 + w \cdot (\text{clean firings}) \quad \beta = \beta_0 + w \cdot (\text{false positives})$$

The weight w is the load-bearing part. Raw firing counts vary over orders of magnitude, and a rule firing tens of thousands of times would otherwise swamp the prior and collapse the posterior to a near-deterministic point. A capped down-weight bounds the effective evidence any single technique can contribute, so a very high-volume rule cannot manufacture false certainty. Confidence still grows with evidence; it is simply prevented from running away.

4.2 Cold start from the bucket

When a technique has no per-rule firing counts, the posterior is seeded from its bucket with pseudo-counts that encode the bucket's operational meaning:

Bucket	Evidence added (α , β)	Effect on breach probability
detected	(strong α)	Lowers. Confident, clean firing.
deployed-noisy	(split α/β)	Modest. Fires, but false-positive-heavy.
deployed-untested	(none, prior only)	Neutral. Honest doubt at 0.5.
deployed-blind	(strong β)	Raises. The rule cannot fire.

Bucket	Evidence added (α , β)	Effect on breach probability
deployed-disabled	(strong β)	Raises. Disabled is not coverage.

Techniques with no deployed rule at all, meaning library-only and gap, get *no* posterior entry, so the simulation falls back to its theoretical coverage score for them rather than inventing a firing signal where none exists. The deployed-blind and deployed-disabled downgrades are the whole point: they push detection below the neutral prior, which is what corrects illusory coverage.

5. Sampling Uncertainty into Breach Probability

A point estimate of detection throws away how *sure* we are. The simulation instead *samples* the posterior: on each Monte Carlo iteration, each step draws its detection probability from the technique's Beta distribution. A technique with little evidence has a wide distribution, so its detection probability varies widely across iterations and its uncertainty propagates into the spread of breach probability. A technique with abundant clean firings has a tight distribution and contributes a stable discount. This mirrors how the simulation already samples transition probabilities, so detection uncertainty and exploitation uncertainty flow through the same machinery.

The sampled quantity is the probability of *detection*. It is kept distinct from the probability of *blocking given detection*, which remains a separate factor. Detecting a step and stopping it are different events, and conflating them would double-count. The posterior refines only the detection term; the exploitation model is untouched, because firing data measures detection, not how hard a technique is to execute.

6. The Regression Lock

Because the simulation is the heart of the risk score, one invariant is non-negotiable: an organization with no SIEM telemetry, and therefore no posterior data for any technique, must reproduce the prior behavior *exactly*.

The guarantee is structural. When no per-technique posterior exists, the detection step takes the original code path and issues the identical sequence of random draws, so the Monte Carlo stream, the blocked-step outcomes, and the resulting breach probability are bit-identical to the pre-posterior model. A single uniform draw per step feeds both the reported detection metric and the path-progression test, so introducing the posterior adds no draw on the no-data path. A dedicated test pins the invariant, and it ships before any behavioral change.

Score movement is intended, and visible

Organizations with live SIEM telemetry will see breach probability *rise* where coverage was illusory, whether from rules that looked covered but never fire, or rules that cannot. That is the corrected, honest number, and it is surfaced as such rather than smoothed away. The regression lock guarantees the change touches only organizations that actually have firing data; everyone else sees exactly the prior behavior.

7. Architecture Notes

Two placement decisions keep the loop clean. The rules-to-firings join and the Beta fit live in the posture-scoring service, which already owns SIEM coverage; it publishes a pre-computed per-technique posterior digest. The simulation consumes that digest as a pure reader, warmed at worker startup exactly like its existing coverage cache, so the join is not duplicated across services and the simulation stays decoupled from the SIEM key layout.

Firing data moves on a periodic polling cadence, so startup warming is sufficient for a first version; periodic re-warming is a natural refinement.

The posterior is one term in a broader closed loop. Upstream, the same firing buckets correct the organization's headline detection-posture score, so a rule that is deployed but never fires no longer counts as coverage there either. The bucket-to-tier mapping carries one deliberate trap worth naming: a "deployed-blind" technique (rule present, telemetry missing) is the opposite of an "uncovered" technique (no rule at all), and mapping the two together by name would mislabel a fixable telemetry gap as a total blind spot. The mapping keeps them distinct.

8. Conclusion

A breach simulation is only as honest as its detection signal, and a deployed rule that never fires is not a detection signal; it is an assumption wearing a detection signal's clothes. By fitting a per-technique Beta posterior to real SIEM firing evidence, sampling its uncertainty into the Monte Carlo breach computation, and driving deployed-but-silent coverage below the neutral prior, the Adversarix platform makes detection an *empirical* term in the risk score rather than an assumed one. The result raises breach probability exactly where coverage is illusory and lowers it exactly where rules fire cleanly, while guaranteeing, byte-for-byte, that an organization without telemetry sees no change at all.

Citation. Galappatti, K. (2026). *Empirical Detection Posteriors: Closing the Loop from SIEM Firings to Breach Probability*. AEGIS Labs, Adversarix, Inc. github.com/Adversarix/aegis-labs

This whitepaper is released for public reference and citation. Reproduction in whole or in part requires attribution. No rights are granted to the underlying platform software or its implementation.